

DNS Recon

1. 개념

- a. 칼리 리눅스에 내장된 **Python** 기반의 강력한 DNS 정보 수집 도구
- b. 세밀한 옵션 지정(`-t`)을 통해 Zone Transfer, Brute Force, DNSSEC Zone Walking 등 특정 공격만 골라서 수행 가능

2. 동작 프로세스

- a. 표준 레코드 열거 (**Standard Record Enumeration**)
: 대상 도메인의 SOA, NS, A, AAAA, MX(메일서버) 등 기본 레코드 정보를 조회
- b. **Zone Transfer** 시도 (**AXFR Check**)
: 발견된 모든 네임서버(NS)를 대상으로 존 전송(AXFR) 요청을 보내 취약점 여부를 확인하고 성공 시 데이터 탈취
- c. 서브도메인 브루트 포스 (**Brute Force**)
: 사전 파일(Dictionary)을 이용하여 서브도메인을 무차별 대입하고, 실제 존재하는 도메인(IP응답)을 식별
- d. 구글 검색 활용 (**Google Enumeration**)
: 검색 엔진을 통해 인덱싱된 서브도메인 정보를 수집 (**Passive** 방식)

e. DNSSEC Zone Walking 및 SRV 조회

: (DNSrecon만의 특징) DNSSEC 설정 미흡(NSEC)을 이용해 존 데이터를 걷듯이 수집하거나, 특정 서비스(VoIP 등)의 SRV 레코드를 조회

3. 옵션 정리

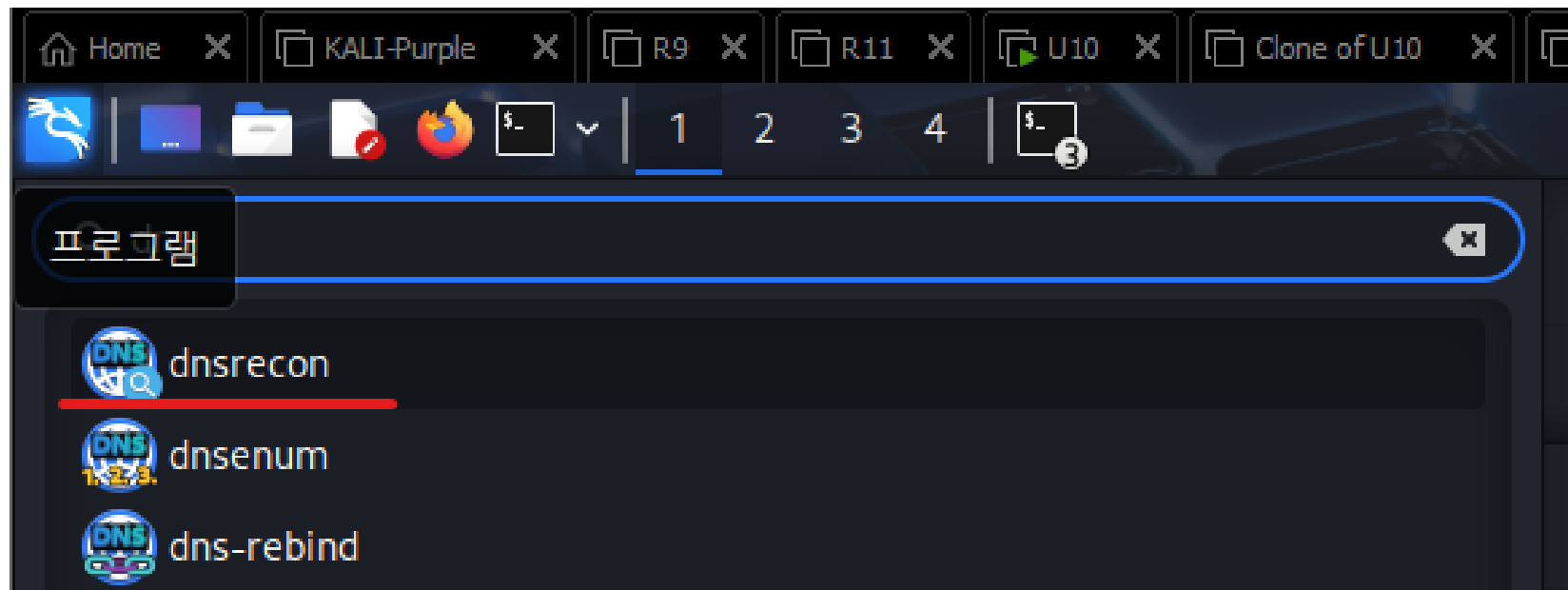
옵션	설명
-d [도메인]	대상 도메인을 지정합니다. (필수)
-t [타입]	수행할 스캔 타입을 지정합니다. - std: 기본(SOA, NS, A, AAAA, MX 등) - axfr: 존 전송 시도 - brt: 사전 파일 이용한 브루트 포스 - rvl: 역방향 조회(Reverse Lookup)
-D [파일경로]	브루트 포스에 사용할 사전(Dictionary) 파일을 지정합니다. (-t brt와 함께 사용)
-r [IP범위]	역방향 조회(Reverse Lookup)를 수행할 IP 대역을 지정합니다. (CIDR 형식 등)
-a	표준 열거(std)와 존 전송(axfr)을 동시에 수행합니다.
-j [파일]	결과를 JSON 또는 CSV 파일로 저장합니다.
--csv [파일]	

[사용예시]

<code>dnsrecon -d example.com</code>	가장 기본적인 정보 수
<code>dnsrecon -d example.com -t axfr</code>	존 전송 시도(Zone Transfer)
<code>dnsrecon -d example.com -D /usr/share/wordlists/dnsmap.txt -t brt</code>	서브도메인 무차별 대입(Brute Force)
<code>dnsrecon -r 192.168.1.0/24</code>	IP 대역 역방향 조회
<code>dnsrecon -d example.com -a --csv result.csv</code>	결과 파일 저장

4. 실습

칼리 리눅스 > dnsrecon 검색 > 프로그램 실행 > cmd창 open



a. 기본 종합 스캔 (Standard Scan)

`dnsrecon -d hrpark.com` *옵션 `-d` = 도메인 지정

```
(rim@kali)-[~]
$ dnsrecon -d hrpark.com
[*] std: Performing General Enumeration against: hrpark.com ...
[-] DNSSEC is not configured for hrpark.com
[*] SOA ns.hrpark.com 172.16.11.100
[*] NS ns.hrpark.com 172.16.11.100
[-] Recursion enabled on NS Server 172.16.11.100
[*] Bind Version for 172.16.11.100 "9.16.23-RH"
[*] A hrpark.com 172.16.11.100
[*] AAAA hrpark.com ::1
[*] Enumerating SRV Records
[-] No SRV Records Found for hrpark.com
```

-> [-] DNSSEC is not configured for hrpark.com

DNSSEC(DNS 보안 확장)이 설정되어 있지 않음 : 도메인 위/변조 공격에 대해 추가적인 보안 서명이 없다는 뜻

-> [*] SOA ... 172.16.11.100 / [*] NS ... / [*] A ...

DNS 서버(NS)와 웹 서버(A)가 모두 172.16.11.100이라는 사설 IP를 사용

-> [-] Recursion enabled on NS Server 172.16.11.100

DNS 재귀 쿼리(Recursion)가 켜져 있음 >> 보안 관점: 외부에서 이 서버를 통해 다른 사이트(예: google.com)의 IP를 물어봐도 대답해준다는 뜻입니다. 실제 서비스 운영 시에는 ****DNS 증폭 공격(DDoS)****에 악용될 수 있어 보안상 막는 것이 권장

-> **[*] Bind Version ... "9.16.23-RH"**

DNS 서버 프로그램인 BIND의 버전이 9.16.23 (Red Hat 버전)

해커가 서버의 구체적인 버전을 알면, 해당 버전의 취약점을 찾아 공격하기 쉬워지므로 보통 보안 설정(configuration)에서 버전을 숨기는 것(version "none";)을 권장

-> **[*] AAAA hrpark.com ::1**

IPv6 주소가 ::1 (로컬호스트, 내 컴퓨터)로 설정되어 있음

IPv6로 접속을 시도하면 자기 자신에게 연결된다는 뜻인데, 실제 운영 환경이라면 제대로 된 IPv6 주소를 넣거나 레코드를 삭제하는 것을 권장

b. Zone Transfer 공격만 시도 (AXFR)

```
dnsrecon -d zonetransfer.me -t axfr
```

```
(rim@kali)-[~]  
$ dnsrecon -d zonetransfer.me -t axfr  
[*] Checking for Zone Transfer for zonetransfer.me name servers  
[*] Resolving SOA Record  
[+] SOA nsztl1.digi.ninja 81.4.108.41  
[*] Resolving NS Records  
[*] NS Servers found:  
[+] NS nsztl1.digi.ninja 81.4.108.41  
[+] NS nsztl2.digi.ninja 5.196.105.10  
[*] Removing any duplicate NS server IP Addresses ...  
[*]  
[*] Trying NS server 5.196.105.10  
[+] 5.196.105.10 Has port 53 TCP Open  
[+] Zone Transfer was successful !!  
[*] SOA nsztl1.digi.ninja 81.4.108.41  
[*] NS nsztl1.digi.ninja 81.4.108.41  
[*] NS nsztl2.digi.ninja 5.196.105.10  
[*] NS intns1.zonetransfer.me 81.4.108.41  
[*] NS intns2.zonetransfer.me 5.196.105.10  
[*] TXT google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VLM  
ewxA
```

c. 사전 대입 공격 (**Brute Force**) - 개별 실습

1. **testrecon** 파일을 홈디렉토리에 만들기

2. **cd ~**

**** 바탕화면 경로에 파일 생성 / 다른 경로 사용 시 명령어 **-D** 옵션 뒤에 파일이 있는 경로도 추가해줘야합니다.**

ex) -D /usr/share/dnsenum/dns.txt

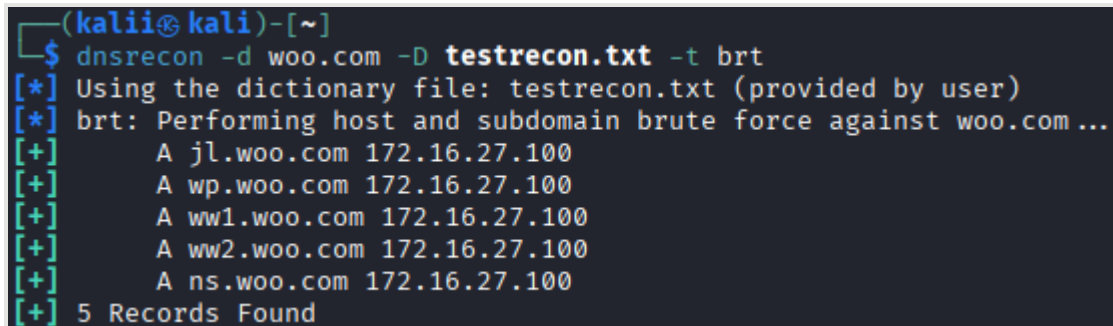
3. **vim testrecon.txt**

4. 붙여넣을 내용

```
www  
vpn  
internal  
office  
staging  
testing  
docs  
owa
```


5. 명령어

```
dnsrecon -d woo.com -D testrecon.txt -t brt
```



```
(kali@kali)-[~]  
$ dnsrecon -d woo.com -D testrecon.txt -t brt  
[*] Using the dictionary file: testrecon.txt (provided by user)  
[*] brt: Performing host and subdomain brute force against woo.com ...  
[+] A jl.woo.com 172.16.27.100  
[+] A wp.woo.com 172.16.27.100  
[+] A ww1.woo.com 172.16.27.100  
[+] A ww2.woo.com 172.16.27.100  
[+] A ns.woo.com 172.16.27.100  
[+] 5 Records Found
```

=> 숨겨진 서브도메인들이 사전대입을 통해 즉시 발견됨을 확인!

4. 결론

DNSrecon은 `-t` (타입) 옵션을 사용하여 원하는 공격 방식(**AXFR, Brute Force** 등)을 명확하게 지정해서 수행할 수 있는 정교한 도구

[로그 확인]

실시간 확인 명령어 : journalctl -u named -f

- **RHEL 계열 (Rocky, CentOS, Fedora):**

`/var/log/messages`

- **Debian 계열 (Ubuntu, Kali):**

`/var/log/syslog`